УСТАВ ПРОЕКТА

Название проекта: BAS-платформа для автоматизированной проверки защищенности корпоративной ИТ-инфраструктуры путем безопасной симуляции сценариев кибератак и оценки эффективности средств защиты. Разработка и внутренняя апробация первой эксплуатационной версии (Фаза №1 программы B2B-продукта).

Спонсор проекта (представитель руководства):

Дата составления: 17.09.26

Менеджер проекта:

Заказчик проекта:

Оглавление

- Обоснование и цели проекта
  - Обоснование и краткое описание проекта
  - SMART цели проекта
  - Краткое описание требований
  - Ожидаемые результаты
- Объём и границы проекта (Scope)
  - Что входит в проект
  - Что НЕ входит в проект
  - Зависимости
  - Ограничения
- Планирование и сроки
- Ресурсы и бюджет
  - Основные статьи расходов
  - Кадровые ресурсы
  - Формат работы
- Управление рисками
- Заинтересованные стороны
- Управление качеством и успехом
  - Критерии успешности проекта
  - Метрики успеха
- Безопасность и соответствие требованиям
  - Требования к информационной безопасности
  - Соответствие нормативным требованиям
- Коммуникация и отчётность
  - План коммуникаций
  - Инструменты и каналы коммуникации
- Технологический стек и решения
  - Архитектура решения
  - DevOps и CI/CD
  - Интеграции и совместимость
- Утверждение и согласование

Обоснование и цели проекта

Обоснование и краткое описание проекта

Проект направлен на создание собственной BAS-платформы (Breach and Attack Simulation) для автоматизированной проверки ИТ-инфраструктуры и оценки эффективности применяемых средств защиты.

Проект реализуется в рамках Фазы №1 комплексной программы развития B2B-продукта и сфокусирован на разработке первой эксплуатационной версии BAS-платформы и ее внутренней апробации. Внедрение такого инструмента позволит организации проактивно выявлять недостатки защитных мер, ограничения платформы и тренировать навыки реагирования сотрудников ИБ. Ожидается, что использование BAS позволит в перспективе сократить затраты на регулярную валидацию средств защиты и уменьшить время обнаружения отдельных тестовых сценариев. Проверка данных гипотез будет проводиться на последующих фазах программы. Результаты Фазы №1 должны сформировать технологическую и методологическую основу для принятия решения о переходе к последующим фазам программы: внешним B2B-пилотам и коммерческому запуску продукта.

Гипотеза дальнейшей коммерциализации

Фаза №1 не ставит целью получение выручки. Результатом фазы является проверка технологической реализуемости и внутренней ценности решения, а также формирование предпосылок для внешних B2B-пилотов. Критериями перехода являются:

- Технологическая готовность

  Первая эксплуатационная версия принята Заказчиком, выполнены обязательные критерии безопасности и функциональности

- Операционная ценность

  Проведена внутренняя апробация и подтверждена полезность результатов для ИБ и IT

- Повторяемость

  Все 6 сценариев могут быть повторно запущены по утвержденному регламенту без существенных ручных доработок

- Масштабируемость

  Подтверждено, что архитектура позволяет расширить набор сценариев, интеграций и реализовать мультиарендность на следующей фазе

Изменения, влияющие на границы, ключевые сроки, бюджет или архитектуру проекта, оформляются через Запрос на изменения и требуют согласования PM, Технического лидера и представителя Заказчика. Изменения, затрагивающие безопасность проведения симуляций, дополнительно согласуются с Директором по ИБ.

SMART цели проекта

К 17.09.2027 разработать и принять первую эксплуатационную версию BAS-платформы, обеспечивающую запуск не менее 6 утвержденных сценариев по 3 векторам атак, интеграцию как минимум с 1 SIEM и 1 EDR, безопасный откат для 100% сценариев и проведение внутренней апробации без критических инцидентов.

Достижимость обеспечивается использованием доказавших эффективность компонентов из открытых источников и наличием внутренней экспертизы. Разработка платформы создаст технологическую базу для внутреннего применения и принятия решения о переходе к внешним пилотам.

Краткое описание требований

Функциональные

- Наличие централизованного "Сервера управления" для координации тестовых кампаний и сбора логов
- Базовая библиотека сценариев, охватывающая векторы фишинга, сетевых атак и ВПО
- Панель мониторинга (дашборд) для визуализации результатов тестирования и оценки реакции существующих средств защиты

Нефункциональные

- В рамках утвержденных сценариев и условий эксплуатации симуляции не должны приводить к недоступности критических сервисов
- Наличие надежного механизма отката изменений после завершения сценария атаки

- Предварительное тестирование всех агентов и сценариев на строго изолированных тестовых стендах, имитирующих продуктивную среду

Ожидаемые результаты

1. Первая эксплуатационная версия BAS-платформы, соответствующая утверждённым границам и требованиям
2. Проведённая внутренняя апробация на согласованном наборе сценариев
3. Подтверждённые результаты интеграции с выбранными СЗИ
4. Отчёт об апробации и выявленных ограничениях
5. Приоритизированный backlog дальнейшего развития продукта, не препятствующий его базовой внутренней эксплуатации
6. Рекомендация по дальнейшему развитию продукта

Объём и границы проекта (Scope)

Что входит в проект

- Разработка ядра платформы
  - Сервер управления (хранение сценариев, управление базой знаний, координация агентов)
  - Модуль планирования и оркестрации (запуск сценариев по расписанию и в реальном времени)
  - Механизм автоматического отката (Cleanup/Rollback) для безопасного удаления артефактов симуляции
  - Агенты и прокси-ноды для работы во внутренних сегментах сети
- Разработка базовых сценариев атак
  - Репозиторий сценариев и скриптов атак по классификатору MITRE ATT&CK для 3 ключевых векторов: фишинг, сетевые атаки и имитация распространения ВПО
- Интеграция со средствами защиты (СЗИ)
  - Модуль корреляции и валидации для сбора логов из внутренних SIEM/EDR систем и фиксации факта обнаружения/блокировки атаки
  - Интеграция не менее чем с одной корпоративной SIEM и одной EDR, выбранными Заказчиком для Фазы №1
- Внутренняя апробация и тестирование
  - Предварительное тестирование производится исключительно на изолированных stage-стендах; внутренняя апробация производится на stage и в заранее согласованных контролируемых сегментах корпоративной инфраструктуры
- Документирование и передача результатов
  - Разработка технической и пользовательской документации, а также итогового отчета о результатах апробации, выявленных недостатках защитных мер и ограничениях платформы

Что НЕ входит в проект

- Поиск, привлечение внешних B2B-партнеров и адаптация платформы под их инфраструктуру (вынесено в Фазу №2)
- Разработка модуля мульти-арендности (multi-tenancy) для изоляции внешних клиентов друг от друга, а также интеграция биллинговых систем и прием платежей (вынесено в Фазу №3)
- Упаковка продукта для коммерческого рынка, проведение маркетинговых кампаний и организация B2B-продаж
- Расчет точного бюджета, сроков и требований для Фаз №2 и №3 (будут оформлены отдельными Уставами по итогам Фазы №1)

Зависимости

- Своевременное предоставление экспертов по информационной безопасности для валидации сценариев атак и составления требований к маппингу техники MITRE ATT&CK
- Предоставление выделенных серверных мощностей, изолированных тестовых сегментов сети и учетных записей для проведения тестов
- Наличие и доступность API-интерфейсов текущих внутренних систем мониторинга (SIEM, EDR) для передачи логов и валидации атак

- Оперативное утверждение сценариев симуляции и регламентов отката со стороны Внутреннего заказчика (Директора по ИБ) и ИТ-департамента

Ограничения

- Текущий Устав жестко ограничен рамками Фазы №1 (12 месяцев). Все параметры последующих фаз определяются отдельными документами
- Проект реализуется строго в рамках выделенной команды и утвержденного лимита бюджета на ФОТ и инфраструктуру
- Вся разработка, тестирование и хранение репозиториев атак осуществляются строго внутри периметра корпорации без привлечения внешних облачных провайдеров на данном этапе

Детальные параметры Фазы №2 (Пилоты) и Фазы №3 (B2B-рынок), включая бюджет, функциональные требования и метрики, намеренно исключены из текущего Устава ввиду высокой неопределенности на старте. Они будут детально рассчитаны и представлены на утверждение в рамках отдельных Уставов **строго по итогам завершения Фазы №1** и прохождения контрольной точки

Планирование и сроки

В рамках представленных вех разработка ведется итеративно; все технологические и исходные архитектурные предпосылки являются предварительными

№	Ключевые Вехи	Задачи	Дата начала	Дата завершения	Ответственный
1	Детализация требований, проектирование и подготовка стендов	Детализация требований, создание USM, архитектурный проект	17.09.2026	17.11.2026	Руководитель проекта / Технический лидер
		Подготовка изолированных тестовых стендов (stage)			
		Утверждение концептуального ТЗ и реестра рисков			
2	Разработка ядра платформы и безопасных агентов	Создание Сервера управления и базы знаний (MITRE ATT&CK)	18.11.2026	17.02.2027	Технический лидер / Backend-команда
		Разработка легких агентов			
		Реализация критически важного модуля автоматического отката (Cleanup/Rollback)			

3	Оркестрация, интеграция с СЗИ и отчетность	Модуль планирования и оркестрации атак	18.02.2027	17.05.2027	Backend-разработчики / DevSecOps
		Интеграция не менее чем с одной корпоративной SIEM и одной EDR, выбранными Заказчиком для Фазы №1; модуль корреляции и валидации логов			
		Модуль аналитики, дашборды покрытия и генерация отчетов			
4	Разработка пользовательского интерфейса (UI) и сборка первой эксплуатационной версии	Рабочий web-интерфейс платформы для управления кампаниями, сценариями, агентами и визуализации результатов	18.05.2027	17.07.2027	Frontend-разработчик / QA-лид
		Разработка ведется итеративно; задачи QA и Security review выполняются параллельно с разработкой соответствующих компонентов			
		Проведение сухого прогона всех сценариев на stage-стенде			
5	Внутренняя обкатка и валидация в контролируемом контуре	Запуск симуляций 3 классов атак в инфраструктуре корпорации	18.07.2027	31.08.2027	Эксперты ИБ / DevSecOps
		Оценка реакции ИБ/IT-отделов и средств защиты			
		Устранение выявленных замечаний и технических багов			
		Регрессионное тестирование после устранения критических замечаний			

6	Приемка первой эксплуатационной версии и завершение Фазы №1	Подготовка технической и пользовательской документации	01.09.2027	17.09.2027	Руководитель проекта
		Составление итогового отчета по обкатке и найденным недостаткам защитных мер и ограничениях платформы			
		Сдача работы Заказчику (принимает продукт по функциональному соответствию) и Спонсору (принимает решение о завершении фазы и финансировании следующей)			

Предварительные сроки Фазы №1

Дата начала: 17.09.2026 **Дата завершения:** 17.09.2027

Продолжительность: 12 месяцев

Ресурсы и бюджет

Плановый бюджет

Общая сметная стоимость: 90 млн. рублей (оценка ROM $\pm 30\%$)

> ФОТ (75%): 67.2 млн. руб. (14 FTE с различной степенью загрузки в зависимости от этапа проекта)
>
> Инфраструктура (10-15%): 12 млн. руб. (серверное оборудование, лицензии)
>
> Резерв (10-15%): 10.8 млн. руб.

Бюджет ФОТ указан с учетом полной стоимости привлечения сотрудника для компании (налоги, страховые взносы и прочие обязательные начисления) и рассчитан по модели максимальной утилизации команды, фактическое списание часов будет производиться согласно ресурсному плану

Основные статьи расходов

- ФОТ (Фонд оплаты труда) 75% бюджета

  Оплата работы выделенной команды разработки, тестирования, DevSecOps и экспертов ИБ за 12 месяцев (14 FTE)

- Инфраструктурные расходы 13.3% бюджета
  - Закупить/выделить серверное оборудование и мощности для центрального «Сервера управления», репозиториев артефактов и очередей сообщений
  - Развертывание и поддержка изолированной среды разработки, тестирования и staging, симулирующей корпоративную сеть
  - Лицензии на специализированное ПО, внутренние средства разработки, средства защиты для стендов и дополнительные лицензии и мощности, необходимые для реализации проекта
- Резервный фонд 12% бюджета

  Резерв на покрытие непредвиденных технических рисков (например, необходимость докупки дополнительных серверных мощностей или привлечение узкопрофильных внешних консультантов по ИБ)

Кадровые ресурсы

№	Роль	Занятость (FTE)	Обязанности
1	Product Owner	0.5	Приоритезация бэклога, критерии приемки, бизнес-ценность
2	Руководитель проекта (PM)	1	Управление проектами (Agile/Waterfall), управление рисками, управление заинтересованными сторонами, Jira/Confluence
3	Технический лидер	1	Архитектура распределенных систем, микросервисы, оркестрация, безопасность приложений
4	Backend-разработчики	4	Разработка легких агентов, REST API, работы с очередями сообщений
5	Frontend-разработчики	1.5	Разработка пользовательских дашбордов, визуализация аналитики и графов атак
6	QA	2	Автоматизация тестирования (Autotests), функциональное и нагрузочное тестирование, проверка сценариев rollback
7	DevSecOps	2	Настройка CI/CD, контейнеризация, Infrastructure as Code (IaC), безопасность сборок и хранилищ артефактов
8	Эксперты ИБ	2	Экспертиза в матрице MITRE ATT&CK, разработка сценариев атак, пентестинг, интеграция с SIEM/EDR, разработка безопасных пейлоадов

14 FTE - это плановая численность проектной команды; фактическая загрузка специалистов варьируется в зависимости от этапа

Формат работы

Место выполнения: Гибридный формат (корпоративный офис / удаленная работа в пределах РФ)

Часовые пояса: UTC+3 (Московское время)

Инструменты коммуникации

- **Управление задачами и документацией:** Jira, Confluence
- **Оперативная коммуникация:** Корпоративный Rocket.Chat / Mattermost
- **Управление кодом и CI/CD:** GitLab / Bitbucket, GitLab CI
- **Формальные уведомления и согласования:** Корпоративная Email-почта
- **Синхронизации:** Еженедельные статус-встречи с командой, ежемесячные отчеты для Спонсора и Заказчика

Управление рисками

Основные риски

№	Область риска	Риск	Вероятность	Влияние	Мера снижения	Владелец
1	Технический / Операционный	Агенты платформы могут вызвать реальный сбой в критической ИТ-инфраструктуре корпорации при имитации атаки	Средняя	Высокое	Разработка надежного механизма автоматического отката (Cleanup/Rollback), обязательное тестирование всех сценариев на изолированных stage-стендах до запуска в прод, утверждение четкого регламента проведения атак	Технический лидер / Эксперты ИБ

2	Информационная безопасность	Взлом самой BAS-платформы или утечка вредоносных артефактов (пейлоадов) из репозитория, что может привести к компрометации сети	Низкая	Критическое	Внедрение практик DevSecOps с первого дня, регулярный аудит кода, шифрование репозитория артефактов, жесткое разграничение прав доступа	DevSecOps-инженер / Эксперты ИБ
3	Технический / Интеграционный	Агенты платформы будут ложно блокироваться внутренними СЗИ, делая симуляцию невозможной	Высокая	Среднее	Внесение агентов в доверенные списки на этапе разработки и тестирование сопряжения с СЗИ	Backend-разработчик / Эксперты ИБ
4	Ресурсный / Сроки	Нехватка времени/ экспертизы ИБ-специалистов для разработки и валидации сложных сценариев атак по матрице MITRE ATT&CK	Средняя	Среднее	Приоритизация бэклога сценариев (жесткая фокусировка в рамках Фазы №1 только на 3 базовых классах: фишинг, сетевые атаки, ВПО), использование стандартных открытых библиотек сценариев	Руководитель проекта (PM)
5	Производительность	Агенты платформы перегружают CPU/RAM на целевых хостах при выполнении сценариев	Средняя	Среднее	Разработка легких агентов с жесткими лимитами потребления ресурсов, обязательное нагрузочное тестирование на stage-стенде	Backend-разработчик / QA-лид
6	Технический / Интеграционный	Доступные интерфейсы выбранных SIEM и EDR могут не предоставлять в полном объеме необходимые для BAS данные или операции, из-за чего интеграция не позволит надежно сопоставлять действия сценария с фактами обнаружения и блокировки	Средняя	Высокое	Проведение раннего технического исследования до начала основной разработки интеграций, согласование доступных интерфейсов и состава необходимых данных, разработка и тестирование минимального коннектора только для чтения на stage-среде; фиксация ограничений интеграции до утверждения архитектуры.	Технический лидер / DevSecOps / Эксперты ИБ

7	Организационный / Сроки	Задержка согласования сценариев, правил безопасного проведения симуляций и условий допуска к контролируемым сегментам со стороны Заказчика, ИБ и ИТ может привести к простою команды и смещению сроков внутренней апробации	Средняя	Высокое	Предварительное согласование календаря контрольных точек и ответственных; подготовка типового шаблона сценария и регламента проведения симуляции; вынесение вопросов, требующих решения Заказчика, в отдельный реестр блокирующих решений; резервирование временных окон для проведения тестирования	Руководитель проекта / Директор по ИБ
8	Технический / Среда тестирования	Конфигурация изолированного stage-стенда может недостаточно соответствовать конфигурации контролируемого корпоративного сегмента, из-за чего сценарии, успешно прошедшие тестирование на stage, могут вызвать ошибки или нежелательное поведение при внутренней апробации	Средняя	Высокое	Формирование базовой конфигурации эталонной среды, максимально возможное воспроизведение используемых ОС и СЗИ; обязательный сухой прогон сценариев; поэтапный допуск сценариев к контролируемому контуру; проведение регрессионного тестирования после изменений среды	Технический лидер / QA-лид / DevSecOps
9	Управление требованиями	В процессе разработки и внутренней апробации может возникнуть запрос на добавление новых сценариев, интеграций или функциональности, не предусмотренных Фазой №1, что приведет к увеличению объема работ и риску нарушения сроков и бюджета	Высокая	Среднее	Фиксация базового scope Фазы №1 и приоритетов требований; ведение backlog; рассмотрение новых требований через установленный процесс управления изменениями; перенос функциональности, не влияющей на приемку первой эксплуатационной версии, в backlog следующих фаз	Руководитель проекта / Product Owner

Заинтересованные стороны

Матрица заинтересованных сторон

№	Заинтересованная сторона	Роль	Уровень влияния	Стратегия взаимодействия
1	Спонсор	Выделяет финансирование, утверждает Устав, принимает решение о переходе к Фазе №2 по итогам апробации первой эксплуатационной версии	Высокое влияние	Ежемесячные отчеты по освоению бюджета и ключевым вехам, участие в управляющих комитетах

2	Внутренний заказчик (Директор по ИБ)	Формулирует функциональные требования к сценариям атак, утверждает регламенты тестирования и принимает результаты обкатки	Высокое влияние	Еженедельные статус-встречи, согласование ТЗ, архитектурных решений и итоговых отчетов
3	Руководитель ИТ-департамента	Предоставляет серверные мощности и изолированные сегменты сети, согласовывает интеграцию со СЗИ и правила проведения атак	Высокое влияние	Двухнедельные синхронизации по ресурсам, жесткое согласование графиков тестирования во избежание накладок
4	Команда разработки, DevSecOps и Эксперты ИБ	Непосредственная разработка ядра, агентов, интерфейса, сценариев атак, проведение тестирования и составление документации	Высокое влияние	Ежедневные Daily Scrum, совместное планирование спринтов в Jira/Confluence
5	Юридический отдел	Проверка платформы на соответствие внутренним нормативным актам, проверка лицензионной чистоты используемых библиотек и компонентов с открытым исходным кодом	Среднее влияние	Согласование результатов на этапе проектирования и перед финализацией первой эксплуатационной версии
6	Отдел продаж и Маркетинг	Ознакомление с возможностями первой эксплуатационной версии для формирования будущего ценностного предложения к Фазам №2 и №3	Минимальное влияние	Демонстрация результатов по завершении ключевых этапов разработки (раз в квартал)

Управление качеством и успехом

Критерии успешности проекта

Функциональные критерии

- Разработано ядро платформы (Сервер управления, Модуль оркестрации) и агенты
- Интегрировано и доступно для запуска не менее 6 сценариев: 2 сценария на каждый из 3 классов сценариев атак (фишинг, сетевые атаки, имитация ВПО)
- Панель мониторинга (дашборд) для визуализации результатов тестирования, статусов выполнения кампаний и валидации логов из СЗИ
- Управление жизненным циклом агента: регистрация, аутентификация, контроль доступности, обновление версии, отключение и безопасное удаление
- Мониторинг состояния платформы: отображение доступности Сервера управления и агентов, статусов выполнения кампаний и сценариев, ошибок выполнения и критических системных событий
- При недоступности Сервера управления или потере связи с агентом выполнение новых сценариев запрещается, а активная кампания переводится в безопасное состояние
- Обновление агентов и сценариев выполняется через контролируемый процесс с версионированием, предварительным тестированием на stage и возможностью отката
- Сценарий запускается из интерфейса, имеет маппинг MITRE, идентификатор кампании, ожидаемый результат. Невозможно запустить сценарий по запрещенной цели
- Платфрорма развернута в согласованном корпоративном контуре, настроены роли и доступы, выполнена передача в эксплуатацию и подготовлена эксплуатационная документация
- Проведен инструктаж сотрудников ИБ, участвующих в эксплуатации платформы

- Определены ответственные за сопровождение платформы, обработку инцидентов и обновление сценариев

Показатели производительности

- Для 100% сценариев первой эксплуатационной версии реализован и протестирован предусмотренный для сценария механизм отката, а результат восстановления подтверждается контрольными проверками
- В ходе внутренней апробации 0 критических инцидентов, вызванных действиями платформы
- 0 случаев недоступности критических продуктовых сервисов, вызванных выполнение сценариев BAS
- Загрузка CPU агентом не должна превышать 5% в пике в ходе штатного выполнения сценария
- Потребление оперативной памяти агентом не должно превышать установленный лимит, определенный на этапе проектиования и подтвержденный нагрузочными тестами
- 100% утвержденных сценариев имеют однозначно определенный результат выполнения и статус телеметрии

Метрики качества

- Отсутствие критических и блокирующих дефектов в ядре платформы на момент сдачи первой эксплуатационной версии Заказчику
- Документация (пользовательская и техническая) полностью описывает процесс развертывания платформы и настройки сценариев

Метрики успеха

Соблюдение сроков

> Разработка, внутреннее тестирование и успешная сдача первой эксплуатационной версии завершены не позднее 17.09.2027 (в рамках плановых 12 месяцев)

Бюджетная дисциплина

> Проект выполнен без превышения планового бюджета на ФОТ и инфраструктурные затраты (допускается использование утвержденного резервного фонда)

Удовлетворённость Заказчика

> Внутренний заказчик официально принял результаты апробации первой эксплуатационной версии (Подписание Акта приемки) и утвердил технический отчет для перехода к Фазе №2

Техническая готовность к масштабированию

> Архитектура первой эксплуатационной версии (ядро, модули, БД) спроектирована таким образом, что позволяет добавить функционал мульти-арендности и биллинга в будущих фазах без полного рефакторинга кода

Безопасность и соответствие требованиям

Требования к информационной безопасности

Безопасность архитектуры и разработки (Application Security & DevSecOps)

- Обязательное внедрение автоматических проверок кода и сканирование зависимостей на известные уязвимости при каждой сборке в GitLab CI
- Хранилище сценариев и репозиторий вредоносных артефактов должны быть зашифрованы с использованием стойких алгоритмов; прямой доступ к ним строго ограничен
- Строгое разграничение ролей в web-интерфейсе платформы (Администратор, Оператор, Аналитик ИБ, Эксперт по сценариям, Руководитель ИБ) с обязательной двухфакторной аутентификацией

Безопасность проведения симуляций (Execution Safety)

- Каждая тестовая атака должна сопровождаться автоматической очисткой целевой системы (удаление созданных файлов, служб, ветвей реестра, учетных записей)
- Агенты платформы должны иметь жестко лимитированные права в ОС и не превышать установленные пороговые значения использования CPU/RAM, чтобы избежать сбоев на целевых хостах
- Сам агент платформы проходит предварительное согласование и при необходимости включается в белый список СЗИ. При этом сценарии симуляции и моделируемая вредоносная активность не должны автоматически исключаться из контроля СЗИ

- Взаимодействие между Сервером управления, Прокси-нодами и Агентами должно осуществляться по защищенному шифрованному каналу с взаимной аутентификацией сторон
- Все действия платформы должны логироваться в некорректируемый журнал аудита для расследования возможных инцидентов
- Любой инцидент, связанный с платформой или проведением симуляции, останавливает выполнение следующих симуляций до завершения расследования и получения разрешения на возобновление работ
- Контрольные процедуры, предшествующие исполнению:
  - белый список целей
  - черный список критических сегментов
  - лимит параллельных запусков
  - лимит времени выполнения
  - kill switch
  - обязательное подтверждение оператора
  - запрет определенных потенциально разрушительных действий
  - расписание

Соответствие нормативным требованиям

Внутренние нормативные акты корпорации (Rules of Engagement)

- Проведение симуляций атак осуществляется точно в соответствии с утвержденным «Регламентом безопасного проведения проверок защищенности»
- Запрет на проведение нерегламентированных симуляций в критических сегментах без предварительного уведомления и одобрения дежурной смены ИБ

Лицензионная чистота ПО и Open Source

- Обязательный аудит всех сторонних библиотек и компонентов с открытым исходным кодом на предмет отсутствия недопустимых лицензий и скрытых закладных элементов

Защита конфиденциальной информации и персональных данных

- Исключение утечки реальных чувствительных данных корпорации при симуляции фишинга или сбора информации (использование только синтетических/тестовых учетных данных и артефактов)
- Полное соответствие внутренним положениям о коммерческой тайне и соглашениям о конфиденциальности

Коммуникация и отчётность

План коммуникаций

№	Целевая аудитория	Информация	Периодичность	Ответственный
1	Управляющий комитет	Высокоуровневый статус выполнения вех, освоение бюджета, ключевые риски и готовность к переходу на Фазу №2	Ежемесячно (Письменный статус-отчет / Управляющий комитет)	Руководитель проекта (PM)
2	Директор по ИБ	Детальный прогресс разработки, результаты спринтов, демо функционала, статус рисков ИБ, утверждение сценариев	Еженедельно (Статус-встреча в формате онлайн) + Демо раз в 2 недели	Руководитель проекта (PM) / Технический лидер
3	ИТ-департамент	Синхронизация по выделению серверных мощностей, согласование графиков симуляций в сети, обсуждение интеграций с СЗИ	1 раз в 2 недели (Рабочая синхронизация онлайн/ очно)	Руководитель проекта (PM) / DevSecOps-инженер

4	Команда разработки, DevSecOps и ИБ	Оперативное планирование, обсуждение блокеров, координация задач по архитектуре, агентам и сценариям атак	Ежедневно (Daily Scrum, 15 мин) + Планирование/ Ретроспектива каждые 2 недели	Руководитель проекта (PM) / Технический лидер
5	Юридический отдел	Проверка лицензионной чистоты используемых библиотек, согласование внутренних регламентов проведения атак	По вехам (при завершении этапов проектирования и сдачи первой эксплуатационной версии)	Руководитель проекта (PM)
6	Отдел продаж и Маркетинг	Информирование о возможностях разрабатываемой платформы для подготовки коммерческого ценностного предложения к Фазам №2/3	1 раз в квартал (Информационная демо-сессия)	Руководитель проекта (PM)

Инструменты и каналы коммуникации

Управление задачами и проектом (Jira)

> Ведение бэклога проекта, планирование спринтов, трекинг задач и багов, отслеживание выполнения вех и диаграмма Ганта

База знаний и документация (Confluence)

> Хранение архитектурных схем, спецификаций сценариев атак по MITRE ATT&CK, протоколов встреч, регламентов проведения симуляций и технической документации

Управление кодом и CI/CD (GitLab)

> Хранилище исходного кода агентов и Сервера управления, репозиторий артефактов, проведение ревью и автоматические проверки DevSecOps

Оперативная коммуникация (Rocket.Chat / Mattermost)

> Защищенный корпоративный мессенджер для ежедневного общения команды, каналы по направлениям (`#bas-dev` , `#bas-sec-scenarios` , `#bas-incidents`)

Встречи и видеоконференции (MTS Link / Telemost / MS Teams)

> Проведение Daily Scrum, демонстраций спринтов, еженедельных статусов и управляющих комитетов

Официальные уведомления и согласования (Корпоративная Email-почта)

> Рассылка официальных статусов, согласование Устава, концептуального ТЗ, актов приемки вех и регламентов проведение атак

Технологический стек и решения

Архитектура решения

Модель развертывания

> Локальная ИТ-инфраструктура корпорации. Использование внешних публичных облаков в рамках Фазы №1 строго исключено из соображений безопасности

Среды и контуры развертывания

> Внутренняя корпоративная сеть (выделенные тестовые stage-стенды и строго ограниченные продуктивные сегменты)

Архитектура

> Распределенная агент-серверная микросервисная архитектура, включающая:
>
> - Центральный узел для хранения сценариев, генерации отчетов и модуля оркестрации (управления расписанием)
> - Промежуточные серверы для обеспечения сетевой связности и ретрансляции служебного трафика от локальных агентов в изолированных контурах и перенаправления его на Сервер управления по разрешенным портам
> - Исполняемые легковесные модули на конечных станциях. Написаны на компилируемых языках. В отдельных сценариях используют легитимные системные механизмы ОС для повышения реалистичности моделируемой активности

DevOps и CI/CD

Инструменты

> GitLab (хранилище кода и CI/CD пайплайны), Docker (контейнеризация Сервера управления), инструменты IaC для подготовки инфраструктуры, специализированные сканеры безопасности исходного кода

Процесс развёртывания

> Автоматизированная сборка серверных компонентов и агентов в GitLab CI/CD. Обязательное применение практик DevSecOps с первого дня, автоматическое сканирование кода на уязвимости при каждом коммите и шифрование репозитория артефактов

Стратегия тестирования

- Unit-тестирование компонентов ядра
- Нагрузочное тестирование агентов (для исключения перегрузки CPU/RAM на конечных станциях)
- Обязательное тестирование всех сценариев атак и механизмов отката на изолированных стендах перед их допуском к запускам в продуктивной среде

Интеграции и совместимость

Интеграция с корпоративными СЗИ (Средствами защиты информации)

> Разработка специализированных API-коннекторов к внутренним системам мониторинга. Платформа должна забирать логи, сопоставлять их по таймстампам с запущенной атакой и отдельно фиксировать статус обнаружения и статус предотвращения сценария: обнаружен / не обнаружен; заблокирован / не заблокирован; результат не определен из-за отсутствия или неполноты телеметрии

Формат описания сценариев

> Использование скриптовых языков, а также YAML/JSON-конфигураций для стандартизованного описания векторов атак (проникновение, закрепление, развитие)

Кроссплатформенность агентов

> Способность исполняемых агентов корректно функционировать на основных операционных системах корпоративной сети (Windows, Linux), поддерживая механизм самоочистки после завершения симуляции

Утверждение и согласование

Подписанием нижеуказанные лица подтверждают своё согласие с условиями настоящего Устава проекта:

Руководитель проекта: _____/

Спонсор проекта (представитель руководства): _____/

Представитель заказчика: _____/

Руководитель ИТ-подразделения: _____/

Дата: